

บทที่ 2

ไฟร์วอลล์

ไฟร์วอลล์นั้นถือเป็นเครื่องมือแรกที่ถูกกำเนิดขึ้นมาในโลกของการรักษาความปลอดภัย (Security) เป็นเครื่องมือที่พัฒนาไปมากที่สุด เป็นที่รู้จักกันมากที่สุด และเป็นเครื่องมือตัวแรกที่มีคนใส่เข้าไปในระบบเพื่อป้องกัน

2.1 ชนิดต่างๆของไฟร์วอลล์ตามการทำงาน

ไฟร์วอลล์ สามารถแบ่งออกได้เป็นหลายประเภท หากทำการจำแนกตามวิธีการทำงาน ก็จะ สามารถแยกได้เป็น 3 แบบ คือ

2.1.1 แพ็กเกจฟิเตอร์ริง (Package Filtering)

เป็นไฟร์วอลล์ที่มีรูปแบบการทำงานที่ง่ายที่สุด และเป็นไฟร์วอลล์แบบแรกที่เกิดขึ้น ซึ่ง ในขณะนี้มักจะเป็นฟังก์ชันการทำงานหลักชิ้นหนึ่งของเราท์เตอร์ (Router) โดยนอกจากจะมีการ ทำงานในการเลือกเส้นทางแล้ว ยังจะทำการกรองแพ็กเกจ (Packet) ที่ผ่านด้วย ก็จะทำการ อนุญาตหรือไม่อนุญาตให้แพ็กเกจนั้นๆ ผ่านเข้าออกไฟร์วอลล์ได้หรือไม่ โดยจะมีการกำหนด รูปแบบของกฎขึ้นมา โดยอาจจะมีการกำหนดให้ปกติเป็นอนุญาตให้ผ่านทุกแพ็กเกจ ยกเว้น แพ็กเกจที่มีรูปแบบตามกฎที่กำหนดไว้ หรือจะเป็นแบบที่ปกติไม่ยอมให้แพ็กเกจใดๆผ่าน ไฟร์ วอลล์ ยกเว้นแพ็กเกจที่มีรูปแบบที่เป็นไปตามกฎที่กำหนดไว้เท่านั้นที่ไฟร์วอลล์ยอมให้ผ่านไปได้ โดยความสามารถของไฟร์วอลล์ประเภทนี้นั้นจะสามารถตรวจสอบได้แต่เฉพาะเฮดเดอร์ (Header) ของแพ็กเกจเท่านั้น โดยจะไม่สามารถเข้าไปตรวจสอบเนื้อหาและการทำแฟร็กเมนต์ชัน (Fragmentation) ของแพ็กเกจได้ และในการทำงานนั้นจำเป็นต้องเปิดพอร์ต (Port) ที่มากกว่า 1024 ไว้ตลอดเวลา จึงอาจเป็นเป้าหมายของการโจมตีได้ ทำให้การทำงานของไฟร์วอลล์ประเภท นี้จะสามารถแค่กรองแพ็กเกจที่เป็นไปตามรูปแบบเท่านั้น แต่ไม่สามารถป้องกันการโจมตีที่ เข้ามายังพอร์ตที่เป็นพอร์ตปกติที่ใช้งาน เช่นพอร์ต 80 ซึ่งจะใช้ในการทำงานปกติ ไฟร์วอลล์ส่วน ใหญ่จะยอมให้แพ็กเกจที่เข้ามายัง พอร์ต 80 ผ่านได้ แต่หากผู้บุกรุกทำการเทลเน็ต (Telnet) เข้า มายัง พอร์ต 80 เพื่อทำการรันโปรแกรมแบ็คดอร์ (backdoor) ไว้ไฟร์วอลล์ก็จะไม่สามารถ ตรวจสอบความผิดปกติได้เลย

2.1.2 สเตตฟูลอินสเปกชัน (Stateful Inspection)

ในไฟร์วอลล์แบบแพ็กเกจฟิเตอร์ริงที่ได้กล่าวมาแล้วนั้น จะเห็นได้ว่าเราสามารถตั้งค่า เพื่อกรองแพ็กเกจที่ไม่ต้องการออกไป แต่ไฟร์วอลล์ดังกล่าว ก็ไม่ปลอดภัยมากพอ เพราะแม้ว่าเรา สามารถจำกัดการเชื่อมต่อให้เหลือแค่พอร์ต 80 เท่านั้นที่ติดต่อเข้ามาได้ แต่ไฟร์วอลล์ข้างต้นก็ไม่สามารถตรวจสอบว่าการเชื่อมต่อนั้นเป็นการเชื่อมต่อปกติหรือไม่ ซึ่งหากเป็นพอร์ต 80 ก็จะ

ปล่อยให้ผ่านหมด ทั้งๆที่แพ็กเกจนั้นอาจจะเป็นแพ็กเกจสำหรับโจมตีก็ได้ และหากเป็นการโจมตีโดยการกำหนดแพ็กเกจให้ผิดปกตินั้น ไฟร์วอลล์จะไม่สามารถรับรู้ได้เลย และไม่สามารถตรวจสอบได้เลย

ข้อบกพร่องทั้งหมดนี้ ไฟร์วอลล์แบบสเตทฟูลอินสเปกชันสามารถป้องกันได้ ซึ่งไฟร์วอลล์แบบสเตทฟูลอินสเปกชันนั้นจะเป็นไฟร์วอลล์ที่มีการตั้งกฎต่างๆเช่นเดียวกับแบบ แพ็กเกจฟิลเตอร์ริง แต่ยังเพิ่มการติดตามสเตทในการเชื่อมต่อเข้าไปด้วย ทำให้สามารถทำนายถึงความผิดปกติที่เกิดขึ้นกับการเชื่อมต่อต่างๆ ได้ว่ามีความปกติ หรือมีความผิดปกติที่อาจสงสัยได้ว่าเป็นการโจมตีได้ ทำให้มีความสามารถทางด้านความปลอดภัยสูงกว่าแบบแรก ในส่วนของความสามารถในการดูแลแพ็กเกจที่ทำการแฟรกเมนเตชัน ไฟร์วอลล์แบบนี้จะทำการรอให้ข้อมูลเข้ามาจนครบ ดาตาแกรม(Datagram) แล้วจึงทำการรวบรวม(Reassemble) เพื่อทำการตรวจสอบว่าเป็นแพ็กเกจที่ถูกต้องหรือไม่ ทำให้การโจมตีในรูปแบบนี้จะทำให้ยากขึ้น และไฟร์วอลล์แบบสเตทฟูลอินสเปกชัน จะไม่ต้องทำการเปิดพอร์ตที่มากกว่า 1024 เนื่องจากการติดตามสเตทของ แพ็กเกจที่เข้าออกทำให้สามารถรับรู้ว่าการเชื่อมต่อนั้นๆเกิดขึ้นที่พอร์ตใดในฝั่งไคลเอนต์ ไฟร์วอลล์จะทำการเปิดเฉพาะพอร์ตที่มีการใช้งานจริงเท่านั้น พอร์ตอื่นๆที่ไม่ได้ใช้งานก็ไม่ต้องเปิด และเมื่อการเชื่อมต่อสิ้นสุดลง ก็จะทำการปิดพอร์ตนั้นๆ ทำให้ระบบมีความปลอดภัยมากขึ้น

อย่างไรก็ตาม ไฟร์วอลล์สเตทฟูลนี้ยังไม่สามารถป้องกันการโจมตีที่แทรกซึมมากับการเชื่อมต่อตามปกติได้ เช่น โพรโตคอล FTP นั้น แม้ว่าไฟร์วอลล์แบบสเตทฟูลจะมีการติดตามให้มีการเปิดพอร์ต 20 อย่างถูกต้อง แต่หากมีการส่งข้อมูลอื่นๆ ที่ไม่ใช่ข้อมูล FTP แทรกมาในระหว่างการเชื่อมต่อ ก็ไม่สามารถรับรู้ได้เลย

2.1.3 แอปพลิเคชันพรอกซี (Application Proxy)

ไฟร์วอลล์แบบนี้จะทำงานในระดับแอปพลิเคชันเป็นสำคัญ โดยไฟร์วอลล์จะทำหน้าที่เป็นตัวแทน(Proxy) ในการเชื่อมต่อ ไปยังเซิร์ฟเวอร์ (Server) โดยในการทำงานนั้น ไฟร์วอลล์ จะทำการรับแพ็กเกจจากไคลเอนต์ (Client) แล้วทำการถอดแพ็กเกจเดิมออกแล้วสร้างแพ็กเกจใหม่ให้มีลักษณะการร้องขอไปยังเซิร์ฟเวอร์ เช่นเดิม เสมือนกับว่าไฟร์วอลล์เป็นผู้ร้องขอไปยังฝั่งเซิร์ฟเวอร์เองทำให้บุคคลภายนอกจะไม่สามารถเห็นหมายเลขไอพีของไคลเอนต์ โดยจะเป็นแค่หมายเลขไอพีของไฟร์วอลล์เท่านั้น และในการตอบกลับก็จะทำการตอบมายังไฟร์วอลล์ รวมถึงสามารถเข้าถึงเนื้อหาของแพ็กเกจได้ ไฟร์วอลล์ประเภทนี้จึงสามารถที่จะกั้นกรองแพ็กเกจที่ไม่เหมาะสมลงไปได้ในระดับข้อมูลได้ แต่เนื่องจากการตรวจสอบที่มากกว่า และยังต้องสร้างแพ็กเกจใหม่ขึ้นมาทุกครั้ง จึงทำให้การทำงานของไฟร์วอลล์ประเภทนี้จะทำงานได้ช้ากว่าแบบอื่น และยังจำเป็นต้องรู้จักการทำงานของโพรโตคอล (Protocol) ที่มากขึ้นเนื่องจากต้องทำการส่งต่อแพ็กเกจโดยการสร้างขึ้นมาใหม่ ดังนั้น การใช้งานโพรโตคอลที่ไฟร์วอลล์ไม่รู้ก็จะทำให้ไฟร์วอลล์ไม่สามารถทำงานได้

2.2 ชนิดของไฟร์วอลล์ตามการอ้างอิงกฎ

แต่หากทำการแยกแยะตามลักษณะการอ้างอิงกฎของ ไฟร์วอลล์ สามารถแบ่งออกได้เป็น 2 ประเภท คือ

2.2.1 แอดเดรสเบสไฟร์วอลล์ (Address-based Firewall)

จะทำงานโดยมีการอ้างอิงกฎกับ แอดเดรส เช่น กฎกำหนดว่า แอดเดรสเครื่อง ก. สามารถทำงานได้แบบหนึ่ง ทำให้เมื่อมีการใช้งานผู้ใช้งานที่ใช้เครื่องที่มีแอดเดรสเป็นเครื่อง ก. จะได้รับสิทธิในการใช้งานเครือข่ายที่เป็นไปตามสิทธิที่ถูกกำหนดไว้ให้กับเครื่องที่ผู้ใช้งาน ได้ ใช้อยู่ แต่หากมีการเปลี่ยนแปลงเครื่อง หรือเปลี่ยนแปลงแอดเดรส สิทธิของผู้ใช้ก็ต้องถูก เปลี่ยนแปลงไปด้วย ทำให้การใช้งานของผู้ใช้ไม่มีความสะดวกเมื่อมีการเปลี่ยนแปลงเครื่อง หรือ ต้องทำการใช้เครื่องมากกว่าหนึ่งเครื่อง เนื่องจากต้องทำการตั้งกฎในทุกเครื่องที่ผู้ใช้ ใช้งานอยู่ และในการใช้งานเครื่องที่มีผู้ใช้งานหลายคน

2.2.2 ยูสเซอร์เบสไฟร์วอลล์ (User-based Firewall)

จะทำงานโดยการอ้างอิงกฎกับผู้ใช้ เช่น ผู้ใช้ ก. สามารถทำงานได้แบบหนึ่ง ซึ่งการใช้ งานของแต่ละผู้ใช้งานจะแตกต่างกันไป ดังนั้นหากมีการเปลี่ยนแปลงเครื่อง ผู้ใช้ก็ยังสามารถทำงาน ภายใต้อัตลักษณ์ของตนเองได้เนื่องจากหากมีการเปลี่ยนแปลงผู้ใช้งาน ตัว ไฟร์วอลล์ก็จะทำการ ปรับเปลี่ยนกฎที่มีอยู่ให้เหมาะสมกับผู้ใช้ที่ทำการใช้งานอยู่ ทำให้เกิดความสะดวกสบายให้กับ ผู้ใช้ คือสามารถทำงานที่เครื่องใดก็ได้ โดยที่ยังได้สิทธิในการใช้งานเครือข่ายได้เหมือนเดิม และ เป็นการอำนวยความสะดวกกับผู้ใช้และระบบด้วยเนื่องจากการจัดการนโยบายเกี่ยวกับความ ปลอดภัยนั้นจะสามารถทำขึ้นได้โดยไม่ต้องทำการกำหนดลงไปถึงระดับแอดเดรส ทำให้การ บริหารจัดการกับนโยบายในระบบที่มีความซับซ้อนสูงทำได้ง่ายขึ้น